



Chapter 03 Whois와 DNS 조사

목차

01 스푸핑 & 스니핑

02 whois 서버 및 hosts 파일

03 DNS

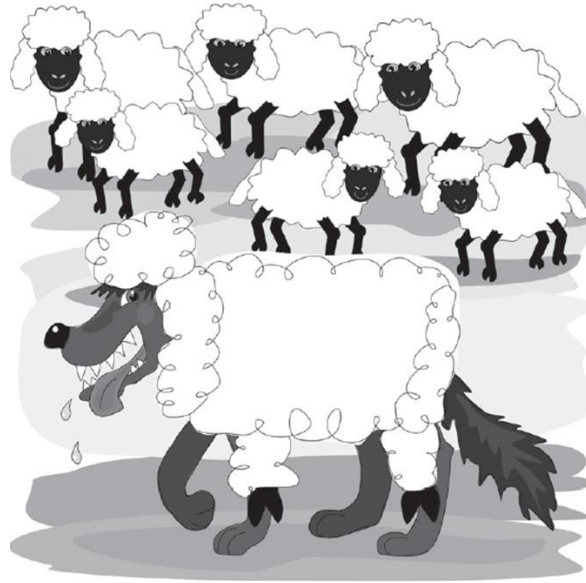
01 스푸핑 & 스니핑



스푸핑 & 스니핑

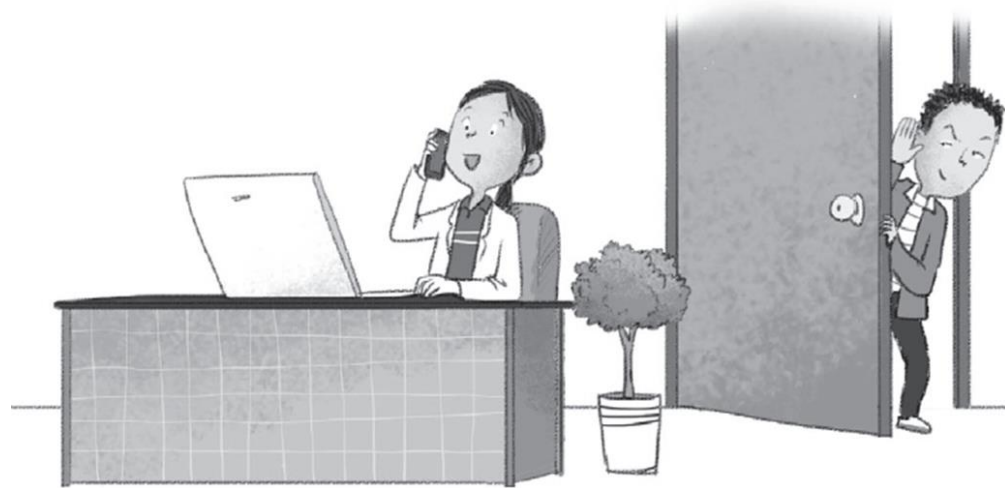
■ 스푸핑

- 속이는 것



■ 스니핑

- 훔쳐보는 것, 훔쳐듣는 것(도청)



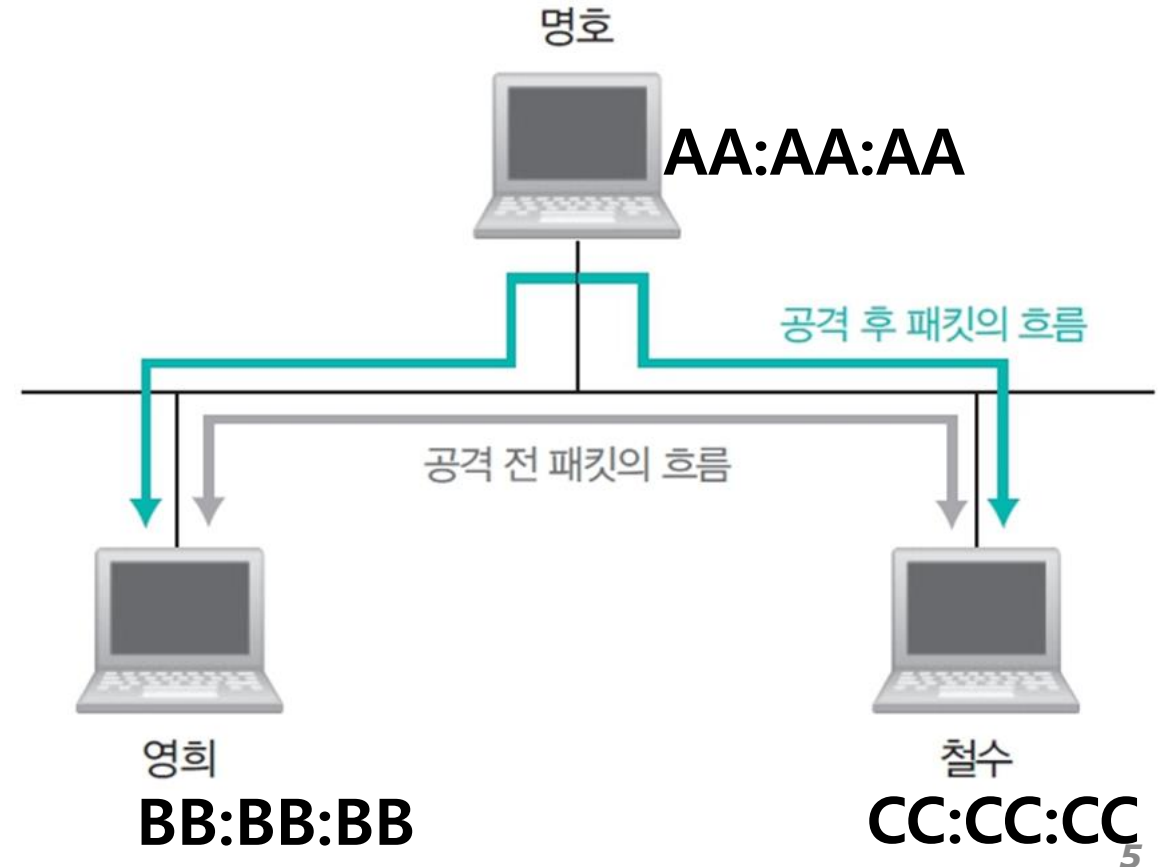
스푸핑 & 스니핑

■ 스푸핑

- 공격자(명호)는 영희와 철수가 대화하는 것을 알고 있음.
- 명호가 영희에게는 철수인 척, 철수에게는 영희인 척하여 둘 간의 대화를 확인

■ ARP 스푸핑

- 스위치 환경에서는 MAC 주소를 이용해 통신
- 명호는 영희에게 철수의 MAC 주소는 AA:AA:AA 라고, 철수에게 영희의 MAC 주소는 AA:AA:AA 라고 메시지를 보냄
- 영희와 철수는 자신들의 ARP 테이블에 철수는 영희의, 영희는 철수의 MAC 주소를 AA:AA:AA라고 저장함
- 영희와 철수는 AA:AA:AA로 메시지를 보냄



스푸핑 & 스니핑

■ 스푸핑 방법(@Linux)

■ 현재 상황

```
root@mail:/etc/bind# arp -a
192.168.nate.com (192.168.245.146) at 08:00:27:ad:27:8f [ether] on enp0s3
192.168.nate.com (192.168.245.239) at 5e:ec:ca:08:3d:2b [ether] on enp0s3
root@mail:/etc/bind# ifconfig
enp0s3: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
    inet 192.168.245.156  netmask 255.255.255.0  broadcast 192.168.245.255
    inet6 2001:2d8:e3b9:4d31:d056:4911:d104:a8a9  prefixlen 64  scopeid 0x0<global>
    inet6 fe80::eebb:f540:ad80:60bb  prefixlen 64  scopeid 0x20<link>
    inet6 2001:2d8:e3b9:4d31:5b02:d96d:9e15:b872  prefixlen 64  scopeid 0x0<global>
    ether 08:00:27:f9:c2:b2  txqueuelen 1000  (Ethernet)
    RX packets 36471  bytes 5783621 (5.7 MB)
    RX errors 0  dropped 12476  overruns 0  frame 0
    TX packets 18738  bytes 2075613 (2.0 MB)
    TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

스푸핑 & 스니핑

■ 스푸핑 방법(@Linux)

- arpspoof 툴 사용 (dsniff 패키지 안에 포함)
- arpspoof -i eth0 -t 타겟 IP 목적지 IP
- 위와 같이 공격하면 타겟IP에게 공격자는 목적지 IP의 MAC을 가지고 있다고 속임
- 공격 시나리오
 - 공격자(146)는 피해자(156)에게 게이트웨이(239) MAC 주소를 146번 IP로 속일 수 있게 됨.

```
root@tn-VirtualBox:/etc/bind# ifconfig
enp0s3: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.245.146 netmask 255.255.255.0 broadcast 192.168.245.255
    inet6 fe80::590e:4038:2de9:381b prefixlen 64 scopeid 0x20<link>
    inet6 2001:2d8:e3b9:4d31:1aa2:20b2:92a6:be98 prefixlen 64 scopeid 0x0<glob
    inet6 2001:2d8:e3b9:4d31:4f0a:2551:bade:e2e prefixlen 64 scopeid 0x0<glob
    ether 08:00:27:ad:27:8f txqueuelen 1000 (Ethernet)
    RX packets 417595 bytes 594613546 (594.6 MB)
    RX errors 0 dropped 12506 overruns 0 frame 0
    TX packets 93531 bytes 6657333 (6.6 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 1309 bytes 117379 (117.3 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 1309 bytes 117379 (117.3 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

root@tn-VirtualBox:/etc/bind# arpspoof -i enp0s3 -t 192.168.245.156 192.168.245.239
```

```
root@tn-VirtualBox:/etc/bind# arpspoof -i enp0s3 -t 192.168.245.156 192.168.245.239
8:0:27:ad:27:8f 8:0:27:f9:c2:b2 0806 42: arp reply 192.168.245.239 is-at 8:0:27:ad:27:8f
8:0:27:ad:27:8f 8:0:27:f9:c2:b2 0806 42: arp reply 192.168.245.239 is-at 8:0:27:ad:27:8f
8:0:27:ad:27:8f 8:0:27:f9:c2:b2 0806 42: arp reply 192.168.245.239 is-at 8:0:27:ad:27:8f
```

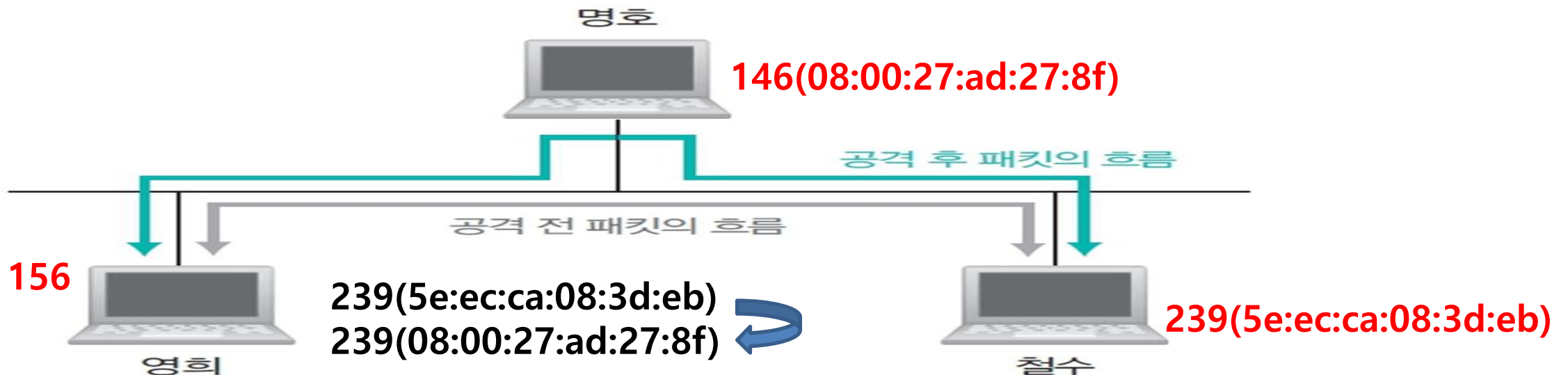
스푸핑 & 스니핑

■ 스푸핑 방법(@Linux)

■ 스푸핑의 결과

- `arp -a` : 자신의 PC에서 arp 테이블의 내용을 전부 출력
- 공격자(146)의 MAC 주소가 게이트웨이(239)의 MAC 주소와 같음

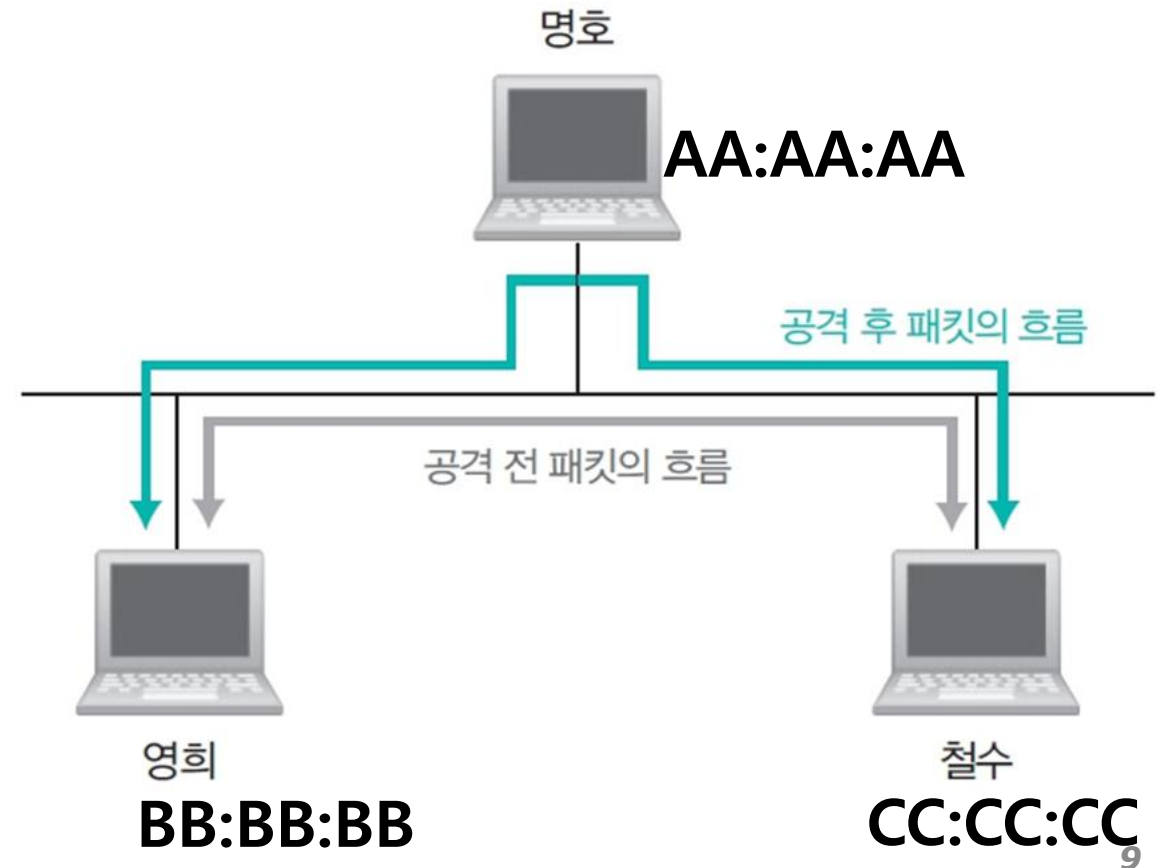
```
root@mail:/etc/bind# arp -a
192.168.nate.com (192.168.245.146) at 08:00:27:ad:27:8f [ether] on enp0s3
192.168.nate.com (192.168.245.239) at 08:00:27:ad:27:8f [ether] on enp0s3
```



스푸핑 & 스니핑

■ 스니핑

- 일반적으로 스푸핑의 결과를 통해 상대방의 메시지를 훔쳐보게 됨.
- 스니핑에는 RELAY가 필요!!
 - 명호는 도청한 후에 영희의 메시지를 철수에게
철수의 메시지를 영희에게 RELAY해 줄 필요!!



스푸핑 & 스니핑

■ 스푸핑 & 스니핑

- 스푸핑과 스니핑은 여러 가지 공격의 기초가 되는 경우가 일반적

02 whois 서버 및 hosts 파일



Whois 서버를 이용한 정보 수집

■ Whois

- 1984년에 만들어진 도메인 확인, 도메인과 관련된 사람과 인터넷 자원을 찾아보기 위한 프로토콜
- 초기에는 와일드카드(*) 문자열로 도메인 검색이 가능했음
- 인터넷이 상업화되고 스팸 메일이 증가함에 따라 이런 기능은 모두 사라짐

■ Whois 서버로 얻을 수 있는 정보

- 도메인 등록 및 관련 기관 정보
- 도메인 이름과 관련된 인터넷 자원 정보
- 목표 사이트의 네트워크 주소와 IP 주소
- 등록자, 관리자, 기술 관리자의 이름, 연락처, 이메일 계정
- 레코드의 생성 시기와 갱신 시기
- 주 DNS 서버와 보조 DNS 서버
- IP 주소의 할당 지역 위치

Whois 서버를 이용한 정보 수집

■ Whois 서버 목록

- 도메인을 등록하면 각 지역별 Whois 서버에 등록

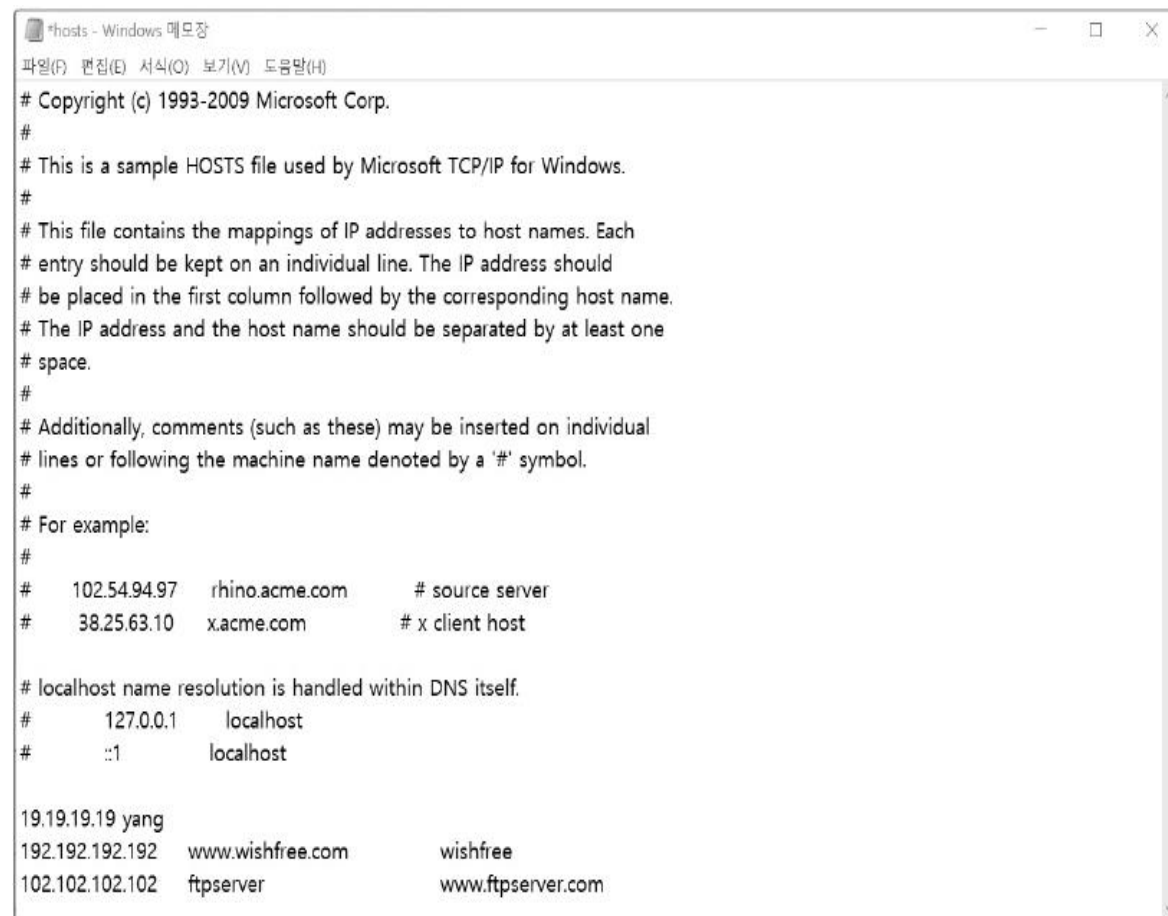
표 3-1 지역별 Whois 서버 목록

담당 지역	Whois 서버
전체	whois.internic.net
유럽	www.ripe.net
아시아 태평양 지역	www.apnic.net
	www.arin.net
호주	whois.aunic.net
프랑스	whois.nic.fr
일본	whois.nic.ad.jp
영국	whois.nic.uk
한국	whois.krnic.net
해커들을 위한 Whois	whois.greektoos.com

hosts 파일을 이용한 정보 수집

■ Hosts 파일

- DNS가 존재하기 전에 사용
 - 특정한 website IP 주소 저장
 - 전화번호 부 같은 역할!!
 - 현재도 목적에 따라 많이 사용됨
- 윈도우 계열 시스템
 - ...windows \ system32 \ drivers \ etc \ hosts
- 리눅스
 - /etc/hosts



```
# Copyright (c) 1993-2009 Microsoft Corp.
#
# This is a sample HOSTS file used by Microsoft TCP/IP for Windows.
#
# This file contains the mappings of IP addresses to host names. Each
# entry should be kept on an individual line. The IP address should
# be placed in the first column followed by the corresponding host name.
# The IP address and the host name should be separated by at least one
# space.
#
# Additionally, comments (such as these) may be inserted on individual
# lines or following the machine name denoted by a '#' symbol.
#
# For example:
#
# 102.54.94.97 rhino.acme.com # source server
# 38.25.63.10 x.acme.com # x client host

# localhost name resolution is handled within DNS itself.
# 127.0.0.1 localhost
# ::1 localhost

19.19.19.19 yang
192.192.192.192 www.wishfree.com wishfree
102.102.102.102 ftpserver www.ftpserver.com
```

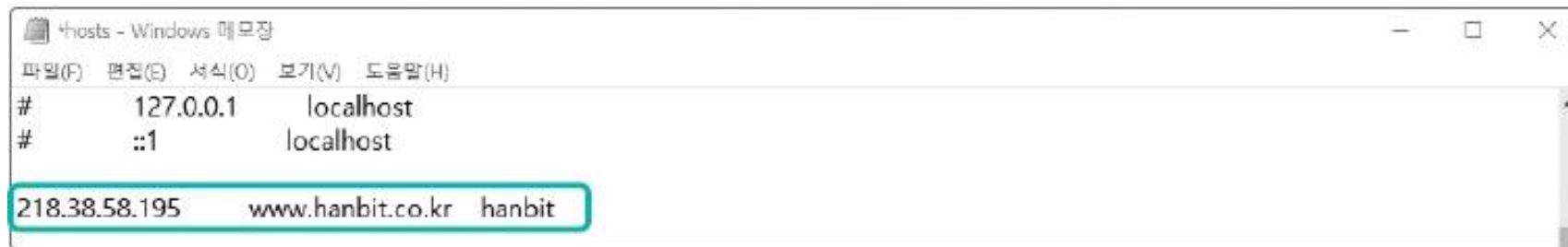
그림 3-1 hosts 파일의 예(C:\windows\system32\drivers\etc\hosts)

hosts 파일을 이용한 정보 수집

■ Hosts 파일의 기본 구조

IP 주소	도메인 이름 또는 임의의 명칭
-------	------------------

그림 3-2 hosts 파일의 구조



- hosts 파일은 보통 비어 있음
- DNS 서버가 작동하지 않을 때 별도의 네트워크를 구성해 임의로 사용하고자 할 때,
- 다른 IP 주소를 가진 여러 대의 서버가 같은 도메인으로 클러스터링(Clustering)되어 운영되는 상태에서 **특정 서버에 접속하고자 할 때** 유용

[실습 3-2] hosts 파일을 이용해 이름 해석하기

1

도메인 등록하기

ping www.hanbit.co.kr

```
명령 프롬프트
C:\Users\alpha>ping www.hanbit.co.kr

Ping www.hanbit.co.kr [218.38.58.195] 32바이트 데이터 사용:
218.38.58.195의 응답: 바이트=32 시간=5ms TTL=128
218.38.58.195의 응답: 바이트=32 시간=4ms TTL=128
218.38.58.195의 응답: 바이트=32 시간=5ms TTL=128
218.38.58.195의 응답: 바이트=32 시간=5ms TTL=128

218.38.58.195에 대한 Ping 통계:
    패킷: 보냄 = 4, 받음 = 4, 손실 = 0 (0% 손실),
    왕복 시간(밀리초):
        최소 = 4ms, 최대 = 5ms, 평균 = 4ms

C:\Users\alpha>
```

218.38.58.195 www.hanbit.co.kr hanbit

```
*hosts - Windows 메모장
파일(F) 편집(E) 서식(O) 보기(V) 도움말(H)
# 127.0.0.1 localhost
# ::1 localhost
218.38.58.195 www.hanbit.co.kr hanbit
```

[실습 3-2] hosts 파일을 이용해 이름 해석하기

2

hosts 파일 동작 확인하기

ping hanbit

```
관리자: 명령 프롬프트
C:\Windows\system32>ping hanbit

Ping www.hanbit.co.kr [218.38.58.195] 32바이트 데이터 사용:
218.38.58.195의 응답: 바이트=32 시간=29ms TTL=128
218.38.58.195의 응답: 바이트=32 시간=6ms TTL=128
218.38.58.195의 응답: 바이트=32 시간=7ms TTL=128
218.38.58.195의 응답: 바이트=32 시간=6ms TTL=128

218.38.58.195에 대한 Ping 통계:
    패킷: 보냄 = 4, 받음 = 4, 손실 = 0 (0% 손실),
    왕복 시간(밀리초):
        최소 = 6ms, 최대 = 29ms, 평균 = 12ms

C:\Windows\system32>
```

ping -a www.hanbit.co.kr

```
명령 프롬프트
C:\Users\alpha>ping www.hanbit.co.kr

Ping www.hanbit.co.kr [218.38.58.195] 32바이트 데이터 사용:
218.38.58.195의 응답: 바이트=32 시간=5ms TTL=128
218.38.58.195의 응답: 바이트=32 시간=4ms TTL=128
218.38.58.195의 응답: 바이트=32 시간=5ms TTL=128
218.38.58.195의 응답: 바이트=32 시간=5ms TTL=128

218.38.58.195에 대한 Ping 통계:
    패킷: 보냄 = 4, 받음 = 4, 손실 = 0 (0% 손실),
    왕복 시간(밀리초):
        최소 = 4ms, 최대 = 5ms, 평균 = 4ms

C:\Users\alpha>
```

[실습 3-2] hosts 파일을 이용해 이름 해석하기

3

잘못된 주소를 등록하여 사이트 접속 차단하기

200.200.200.200 www.hanbit.co.kr



02 DNS



DNS의 작동 원리

■ DNS(Domain Name System)

- 숫자로 구성된 IP 주소를 사람이 이해하기 쉬운 명칭인 도메인 이름으로 상호 매칭시켜주는 시스템
- 일반적으로 URL -> IP 주소

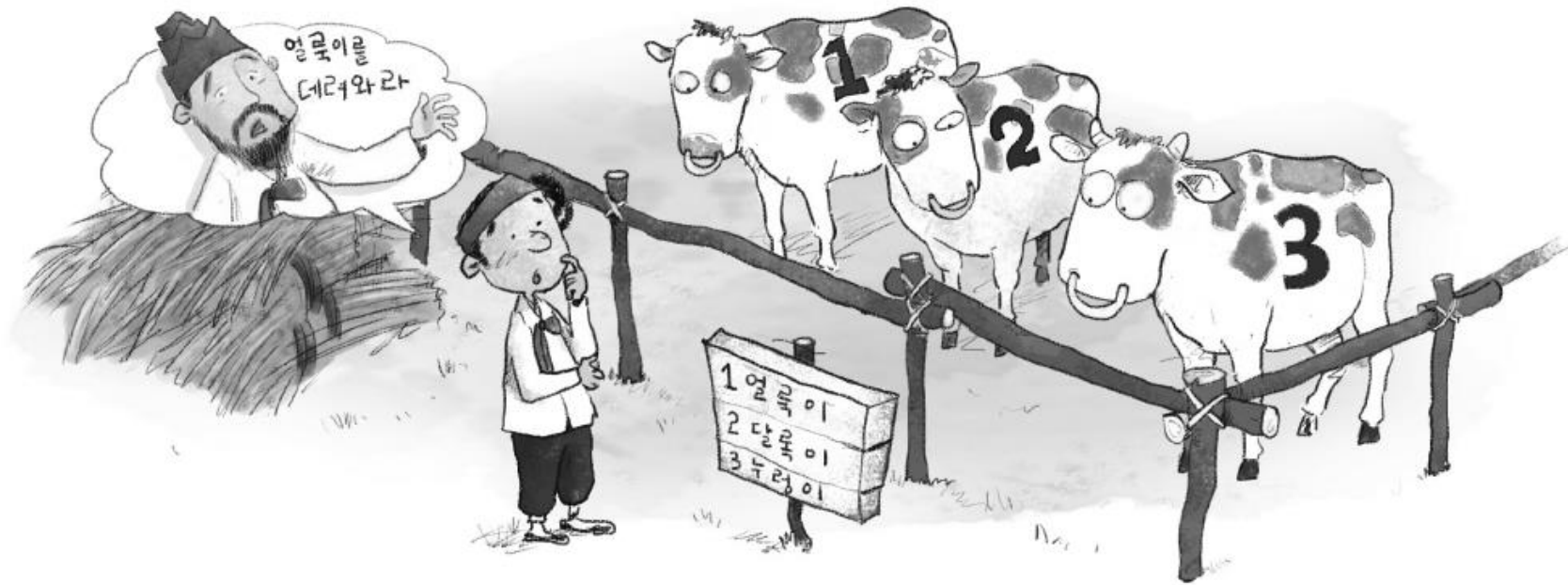


그림 3-3 DNS의 작동 원리 예

DNS의 작동 원리

■ DNS의 계층 구조

- 가장 상위 개체는 '.' (Root)
- 두 번째 개체는 국가와 조직체의 특성
- 보통 맨 앞에 자신의 DNS 서버에서 지정해놓은 www, ftp와 같은 특정 서버의 이름이 옴
- FQDN(Fully Qualified Domain Name) : 완성된 주소(예 : www.wishfree.co.kr)

표 3-2 DNS의 두 번째 개체에 대한 내용

항목	내용	항목	내용
com	영리 기관	mil	군사 기관
net	네트워크 기관	edu	교육 기관
org	비영리 기관	int	국제 기관
gov	정부 기관	kr(Korea), jp(Japan)	국가 이름

DNS의 작동 원리

■ DNS의 계층 구조

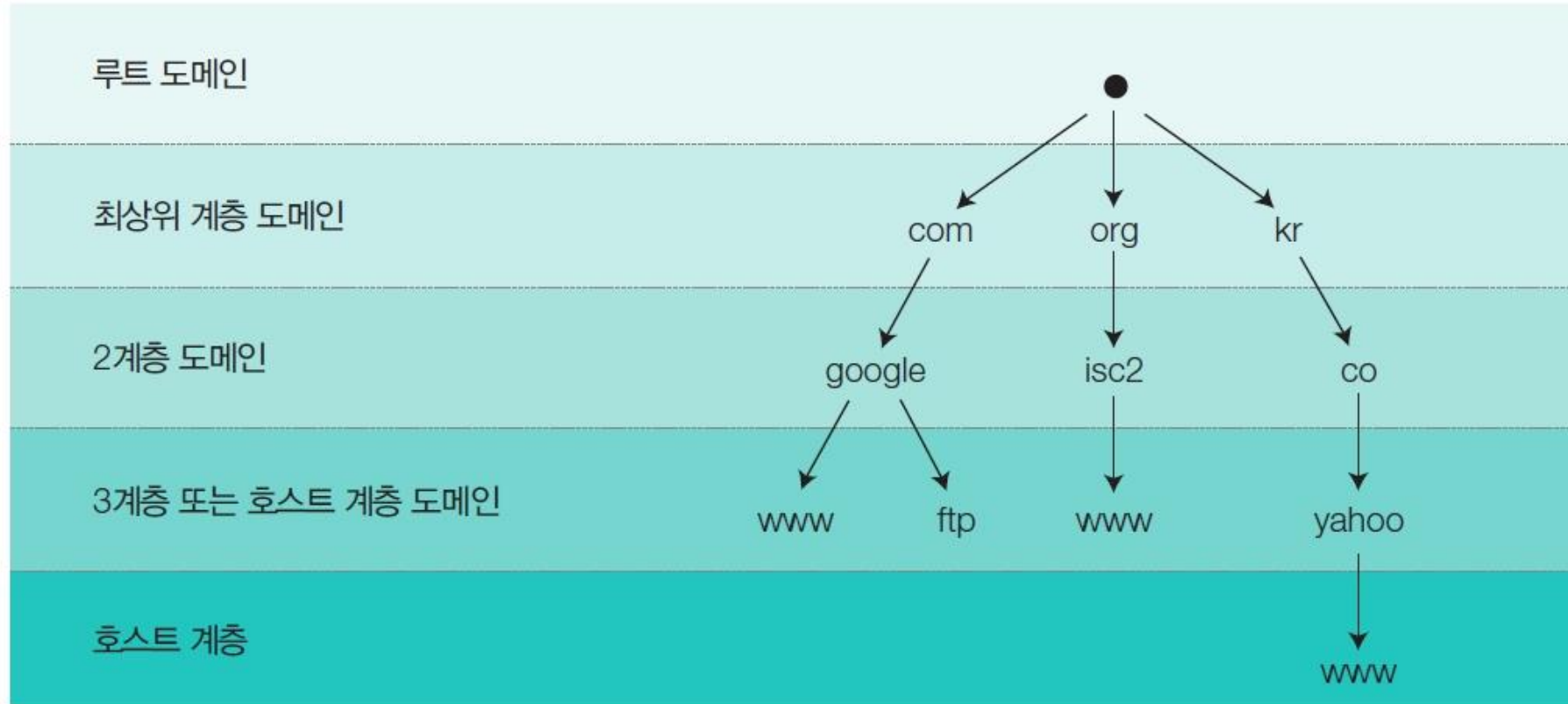
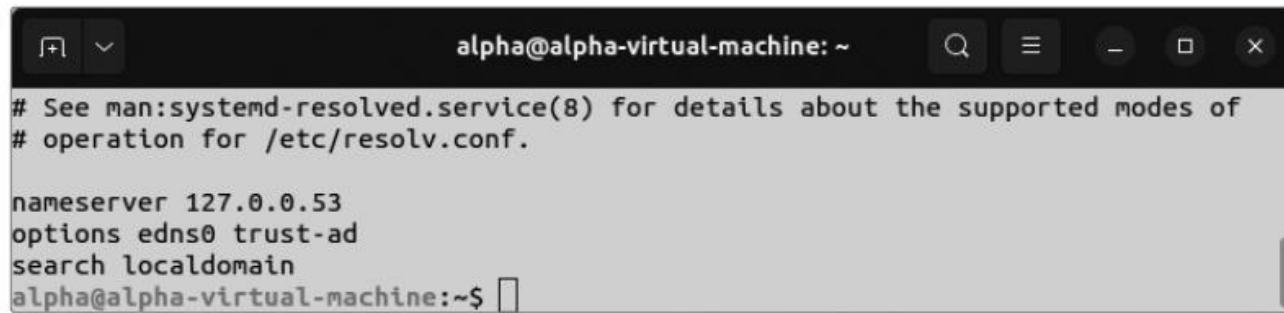


그림 3-4 DNS의 계층 구조

DNS의 작동 원리

■ 운영체제별 DNS 서버 등록

- 리눅스 : /etc/resolv.conf 파일에 DNS 서버를 입력

A terminal window titled 'alpha@alpha-virtual-machine: ~' showing the contents of the /etc/resolv.conf file. The text inside the terminal is: '# See man:systemd-resolved.service(8) for details about the supported modes of', '# operation for /etc/resolv.conf.', 'nameserver 127.0.0.53', 'options edns0 trust-ad', 'search localdomain', and 'alpha@alpha-virtual-machine:~\$' with a cursor.

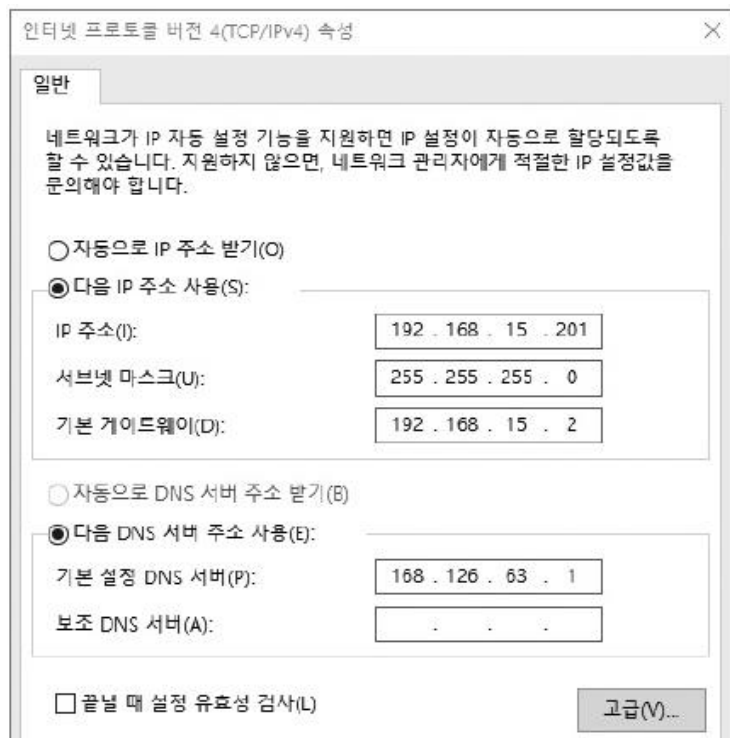
```
alpha@alpha-virtual-machine: ~  
# See man:systemd-resolved.service(8) for details about the supported modes of  
# operation for /etc/resolv.conf.  
nameserver 127.0.0.53  
options edns0 trust-ad  
search localdomain  
alpha@alpha-virtual-machine:~$
```

그림 3-5 리눅스의 DNS 서버 설정(vi /etc/resolv.conf)

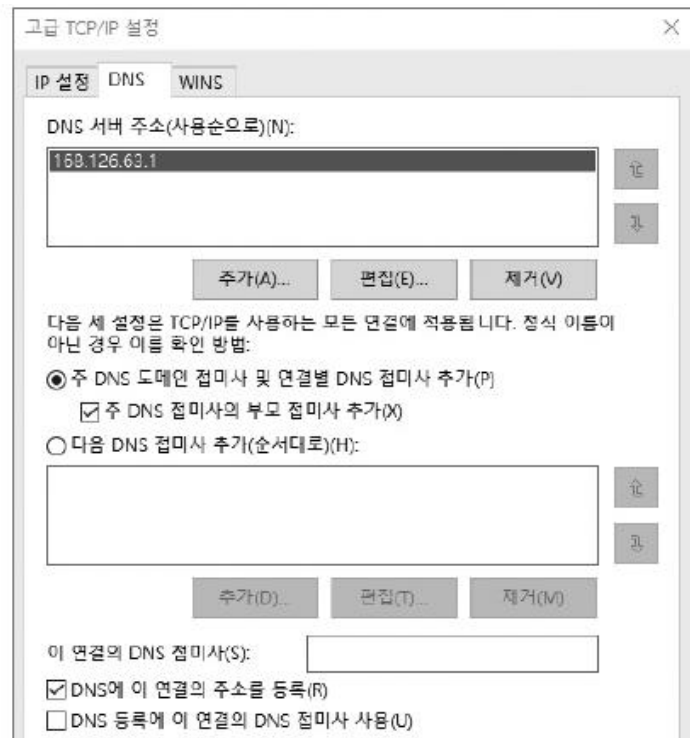
DNS의 작동 원리

■ 운영체제별 DNS 서버 등록

- 윈도우 : 인터넷 프로토콜(TCP/IP) 등록 정보에서 DNS 서버 두 개까지 입력
- [고급] 버튼을 누르면 좀 더 다양한 설정도 가능



(a) 인터넷 프로토콜(TCP/IP) 속성



(b) TCP/IP 고급 설정

그림 3-6 윈도우의 DNS 서버 설정

DNS의 작동 원리

- 명령 창에 ipconfig /all 명령 입력

```
관리자: 명령 프롬프트
C:\Windows\system32>ipconfig /all

Windows IP 구성

호스트 이름 . . . . . : DESKTOP-BCDT852
주 DNS 접미사 . . . . . :
노드 유형 . . . . . : 혼성
IP 라우팅 사용 . . . . . : 아니요
WINS 프록시 사용 . . . . . : 아니요

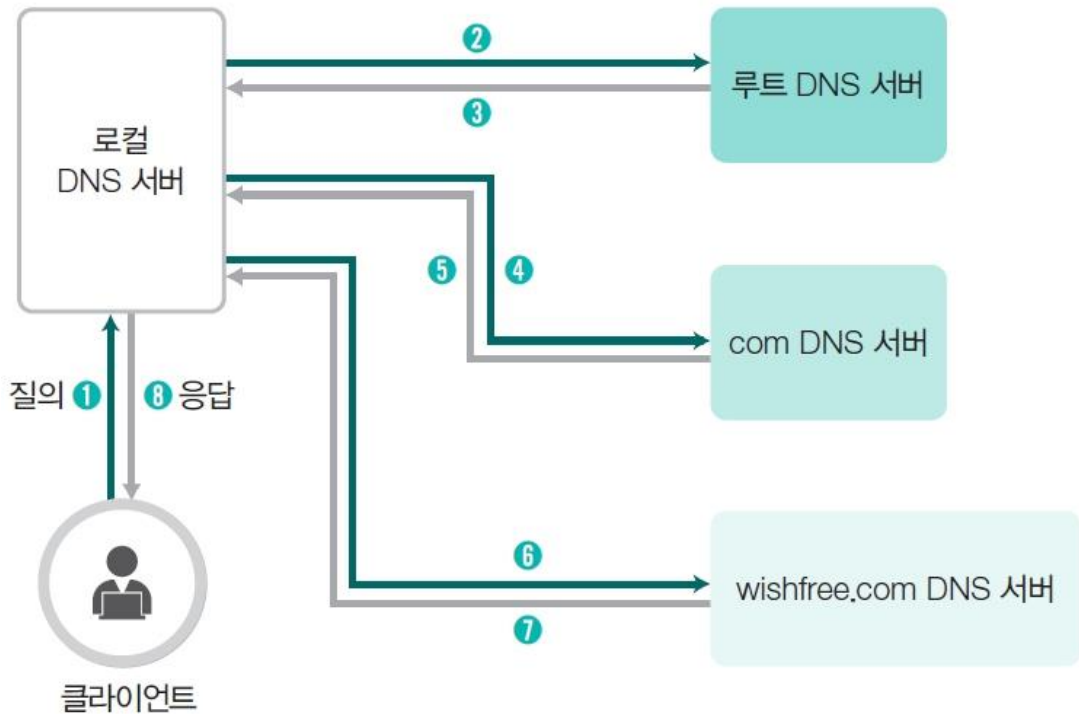
이더넷 어댑터 Ethernet0:

연결별 DNS 접미사 . . . . :
연결별 DNS 접미사 . . . . : Intel(R) 82574L Gigabit Network Connection
물리적 주소 . . . . . : 00-0C-29-67-88-9E
DHCP 사용 . . . . . : 아니요
자동 구성 사용 . . . . . : 예
IPv4 주소 . . . . . : 192.168.15.201(기본 설정)
서브넷 마스크 . . . . . : 255.255.255.0
기본 게이트웨이 . . . . . : 192.168.15.2
DNS 서버 . . . . . : 168.126.63.1
Tcpip를 통한 NetBIOS . . . : 사용
```

그림 3-7 DNS 서버 확인하기(ipconfig /all 명령)

DNS의 작동 원리

■ DNS 서버의 이름 해석 순서



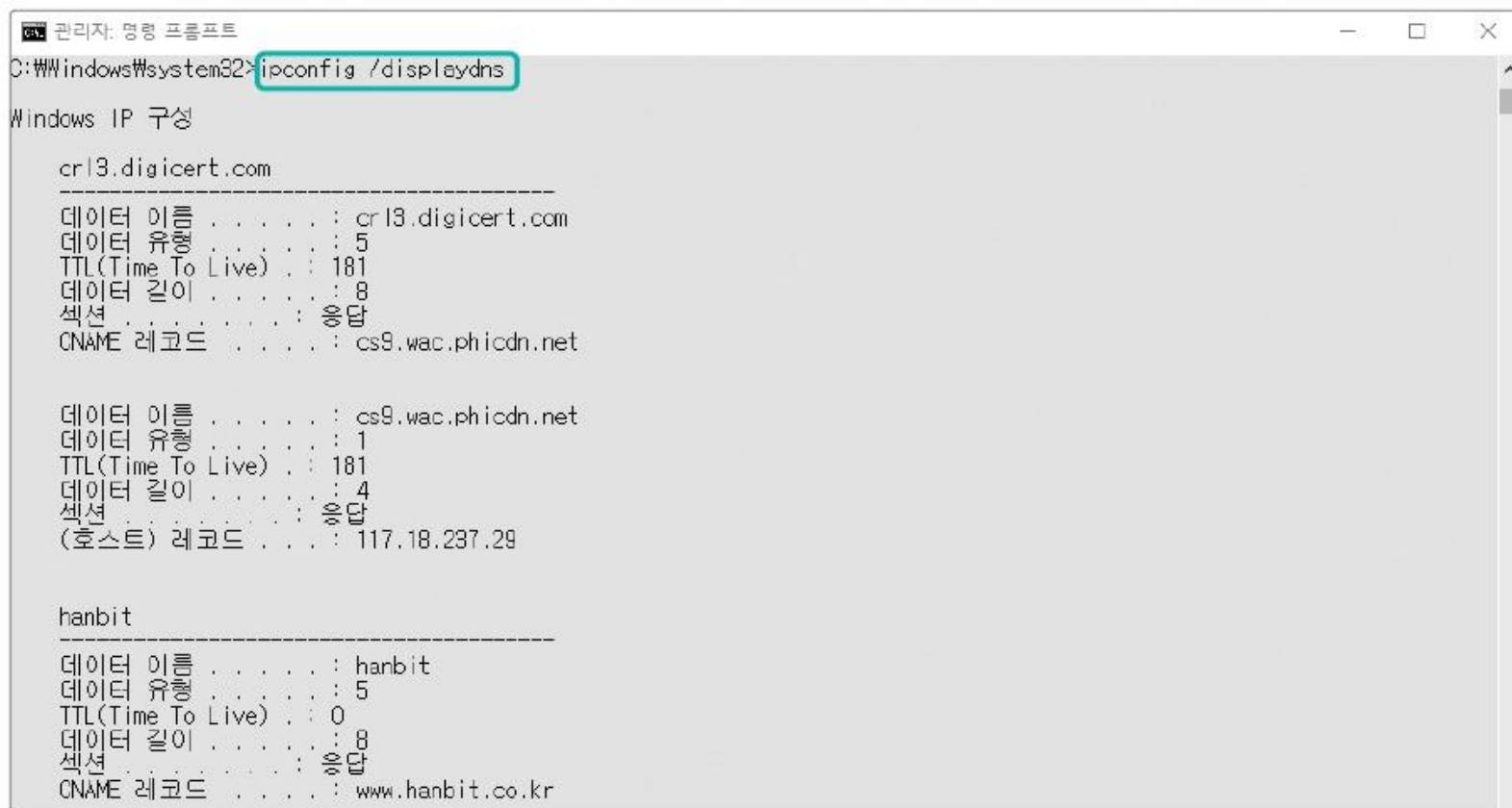
- 1 hosts 파일에 정보가 없으면 시스템에 설정된 DNS 서버인 로컬 DNS 서버에 질의한다.
- 2 로컬 DNS 서버에도 해당 정보가 없으면 루트 DNS 서버에 질의를 보낸다.
- 3 루트 DNS 서버에 `www.wishfree.com`에 대한 정보가 없으면 `com`을 관리하는 DNS 서버에 대한 정보를 보내 준다.
- 4 로컬 DNS 서버는 `com` DNS 서버에 `www.wishfree.com`에 대해 다시 질의한다.
- 5 해당 정보가 없을 경우, `com` DNS 서버는 다시 `wishfree.com`에 질의하도록 로컬 DNS 서버에 보낸다.
- 6 로컬 DNS 서버는 마지막으로 `wishfree.com`의 DNS 서버에 질의한다.
- 7 `wishfree.com`의 DNS 서버로부터 `www.wishfree.com`에 대한 IP 주소를 얻는다.
- 8 해당 IP 주소를 클라이언트에 전달한다.

그림 3-8 DNS 서버의 이름 해석 순서

DNS의 작동 원리

■ 윈도우에서 캐시된 DNS 정보 확인

ipconfig /displaydns



```
관리자: 명령 프롬프트
C:\Windows\system32>ipconfig /displaydns

Windows IP 구성

cr13.digicert.com
-----
데이터 이름 . . . . . : cr13.digicert.com
데이터 유형 . . . . . : 5
TTL(Time To Live) . . : 181
데이터 길이 . . . . . : 8
섹션 . . . . . : 응답
CNAME 레코드 . . . . . : cs9.wac.phicdn.net

데이터 이름 . . . . . : cs9.wac.phicdn.net
데이터 유형 . . . . . : 1
TTL(Time To Live) . . : 181
데이터 길이 . . . . . : 4
섹션 . . . . . : 응답
(호스트) 레코드 . . . . : 117.18.237.29

hanbit
-----
데이터 이름 . . . . . : hanbit
데이터 유형 . . . . . : 5
TTL(Time To Live) . . : 0
데이터 길이 . . . . . : 8
섹션 . . . . . : 응답
CNAME 레코드 . . . . . : www.hanbit.co.kr
```

그림 3-9 윈도우에서 캐시된 DNS 정보 확인

DNS의 작동 원리

■ 윈도우에서 캐시된 DNS 정보 삭제

`ipconfig /flushdns`



```
관리자: 명령 프롬프트
C:\Windows\system32>ipconfig /flushdns
Windows IP 구성
DNS 확인자 캐시를 플러시했습니다.
C:\Windows\system32>
```

그림 3-10 윈도우에서 캐시된 DNS 정보 삭제

DNS의 작동 원리

- 웹 서비스를 요청했을 때, DNS에게 query를 보내기까지 순서
 1. 자신의 컴퓨터에 해당 URL의 IP정보가 캐쉬에 남아 있는지 확인
 2. hosts 파일에서 해당 URL의 IP 정보가 명시되어 있는지 확인
 3. resolv.conf(리눅스) 또는 윈도우 설정에서 DNS IP를 확인한 후 DNS에게 질의(query)
 4. recursive DNS는 자신의 캐시 테이블에 클라이언트가 요청한 URL의 IP가 있는 경우 클라이언트에게 알림
 5. recursive DNS에 해당 URL의 IP가 없는 경우 recursive query를 root DNS부터 보냄!

DNS를 이용한 정보 수집

■ DNS 영역에 대한 전송이란??

- (@중앙대학교 학과 사무실)송실대학교 컴퓨터공학과 "김철수학생"의 전화번호가 무엇인가요?
라고 지나가는 행인이 물으면 답을 해주어야 할까요?
- 송실대학교 컴퓨터공학과 교수가 학생 상담을 위해 요청
- 외부인이 호기심에 요청?



DNS를 이용한 정보 수집

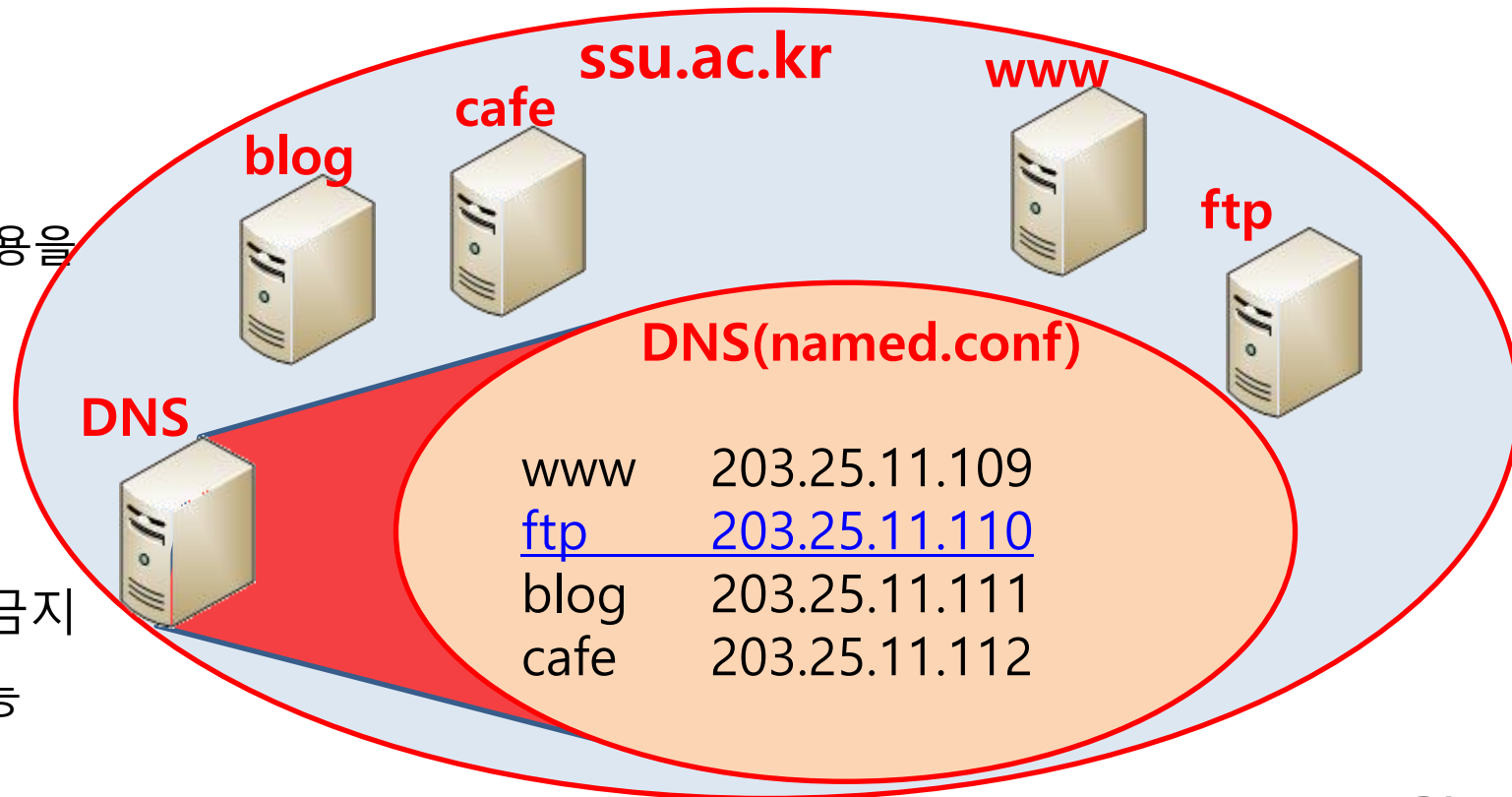
■ DNS 영역에 대한 전송이란??

- 올바른 DNS가 www 서버에 대한 요청을 물었을 때, 알려줌.
- 당신이 관리하는 IP들을 좀 알 수 있을까요?
 - 해커는 ssu.ac.kr 도메인 내의 IP들을 알고 싶어함.

- zone transfer ?
 - zone으로 설정된 네트워크의 IP 내용을 전달해 줄 것인지?

(DNS 영역 전송!!)

- Zone의 내용은 원칙적으로 전송 금지
 - primary가 secondary에게 전달 가능



DNS를 이용한 정보 수집

■ 윈도우에서 DNS 영역에 대한 전송 설정

- 임의의 DNS 영역을 생성한 뒤, 'Property'를 확인 후 [Zone Transfers] 탭에서 DNS 영역에 대한 전송 여부 설정

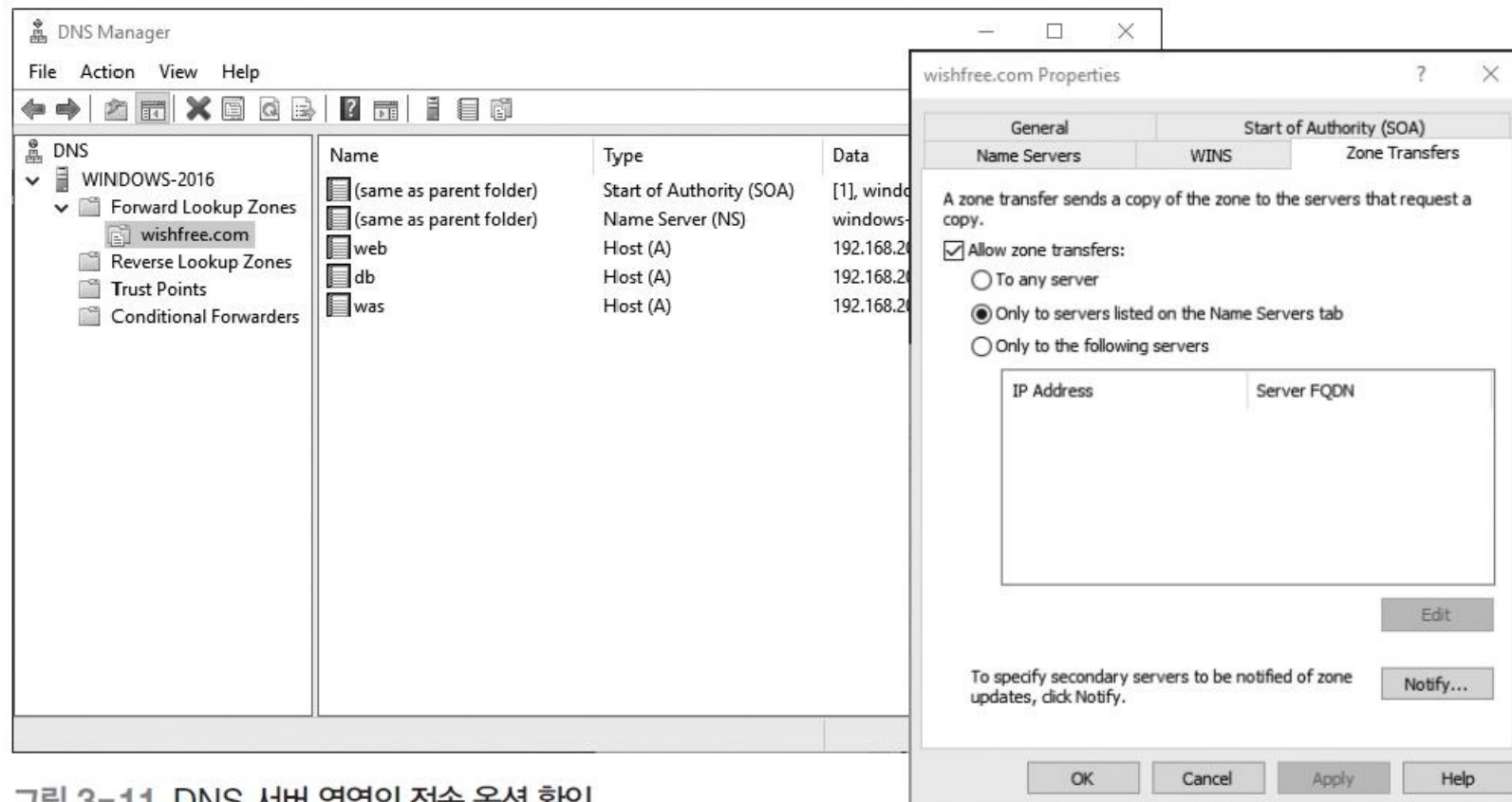


그림 3-11 DNS 서버 영역의 전송 옵션 확인

DNS를 이용한 정보 수집

■ 리눅스에서 DNS 영역에 대한 전송 설정

- /etc/bind/named.conf(또는 /etc/bind/named.conf.local)에서 다음과 같은 형태로 설정

```
zone "wishfree.com" {  
    type master  
    file "db.wishfree.com"  
    allow-transfer (10.10.10.1)  
};
```

- /etc/bind/named.conf.options

```
allow-query {any;};  
// allow-transfer { none;};  
// allow-transfer { none;};
```

- allow-transfer { any | none | 특정 IP }
 - any : 허용, none : 허용안함, 특정 IP : 특정 IP에게 허용(일반적으로 secondary DNS IP)

[실습 3-3] DNS 서버를 검색해 정보 수집하기

실습 환경 • 인터넷이 연결된 클라이언트 시스템(윈도우)

- 존Zone과 해당 영역에 hosts가 등록된 DNS 서버(윈도우 서버)
- 툴: nslookup^{엔에스룩업}, dig^{디그}

1

nslookup 실행하고 DNS 설정하기

nslookup



```
관리자: 명령 프롬프트 - nslookup
C:\Windows\system32>nslookup
기본 서버: kns.kornet.net
Address: 168.126.63.1
>
```

server 168.126.63.1



```
선택 관리자: 명령 프롬프트 - nslookup
> server 219.250.36.130
기본 서버: bns2.hanar.net
Address: 219.250.36.130
> █
```

[실습 3-3] DNS 서버를 검색해 정보 수집하기

2

도메인 정보 수집하기

www.google.co.kr

```
관리자: 명령 프롬프트 - nslookup
> www.google.co.kr
서버: kns.kornet.net
Address: 168.126.63.1

권한 없는 응답:
이름: www.google.co.kr
Addresses: 2404:6800:4004:81f::2003
          142.251.42.163
```

set type=ns

google.co.kr

```
관리자: 명령 프롬프트 - nslookup
> set type=ns
> google.co.kr
서버: kns.kornet.net
Address: 168.126.63.1

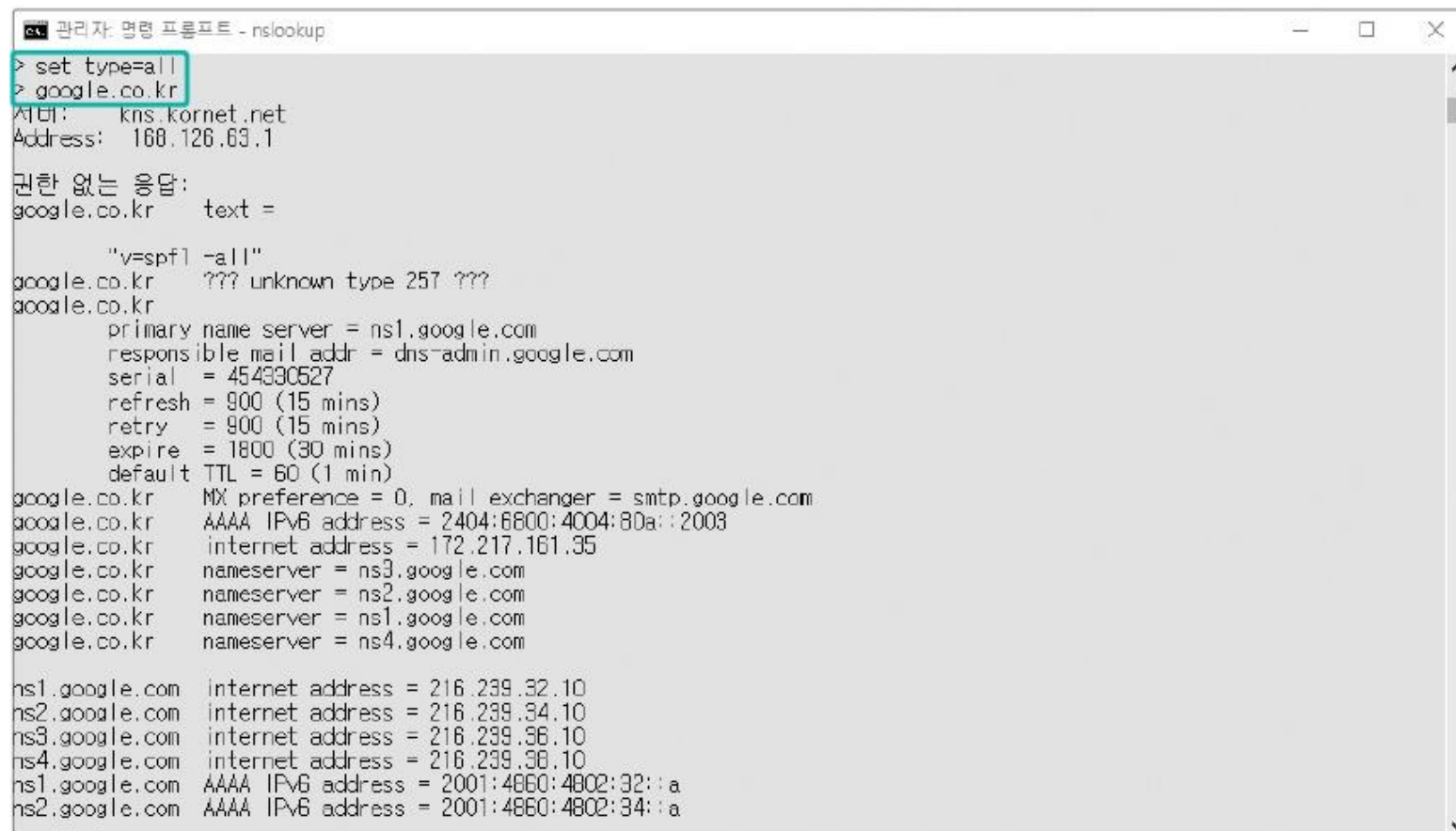
권한 없는 응답:
google.co.kr nameserver = ns4.google.com
google.co.kr nameserver = ns3.google.com
google.co.kr nameserver = ns1.google.com
google.co.kr nameserver = ns2.google.com

ns1.google.com internet address = 216.239.32.10
ns2.google.com internet address = 216.239.34.10
ns3.google.com internet address = 216.239.36.10
ns4.google.com internet address = 216.239.38.10
```

[실습 3-3] DNS 서버를 검색해 정보 수집하기

set type=all

google.co.kr



```
관리자: 명령 프롬프트 - nslookup
> set type=all
> google.co.kr
서버:      kns.kornet.net
Address:  168.126.63.1

권한 없는 응답:
google.co.kr      text =

               "v=spf1 -all"
google.co.kr      ??? unknown type 257 ???
google.co.kr
      primary name server = ns1.google.com
      responsible mail addr = dns-admin.google.com
      serial      = 454390527
      refresh     = 900 (15 mins)
      retry       = 900 (15 mins)
      expire      = 1800 (30 mins)
      default TTL = 60 (1 min)
google.co.kr      MX preference = 0, mail exchanger = smtp.google.com
google.co.kr      AAAA IPv6 address = 2404:6800:4004:80a::2003
google.co.kr      internet address = 172.217.161.35
google.co.kr      nameserver = ns3.google.com
google.co.kr      nameserver = ns2.google.com
google.co.kr      nameserver = ns1.google.com
google.co.kr      nameserver = ns4.google.com

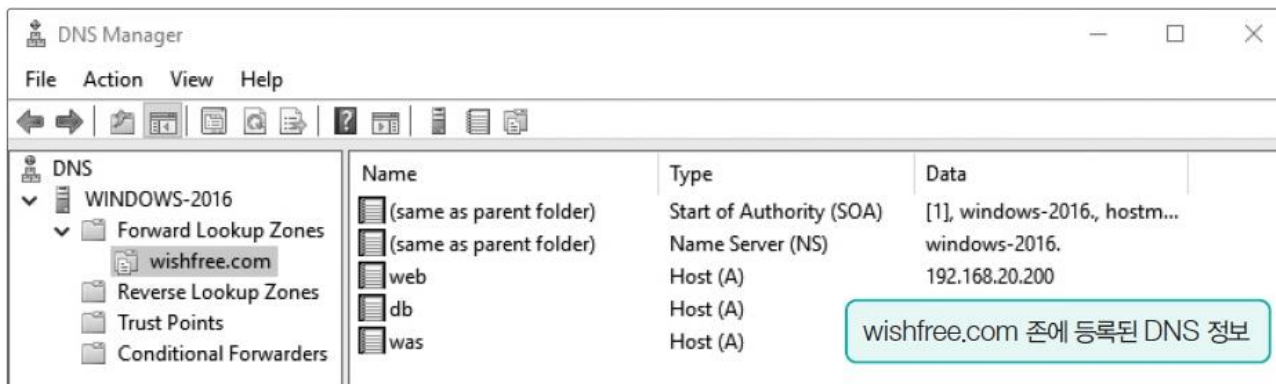
ns1.google.com    internet address = 216.239.32.10
ns2.google.com    internet address = 216.239.34.10
ns3.google.com    internet address = 216.239.36.10
ns4.google.com    internet address = 216.239.38.10
ns1.google.com    AAAA IPv6 address = 2001:4860:4802:32::a
ns2.google.com    AAAA IPv6 address = 2001:4860:4802:34::a
```

[실습 3-3] DNS 서버를 검색해 정보 수집하기

3

DNS 영역 전송하기

- 원도우 서버에 wishfree.com이라는 존을 생성하고 web, db, was 서버를 등록



set type=all

192.168.15.202

wishfree.com



[실습 3-3] DNS 서버를 검색해 정보 수집하기

set type=all

wishfree.com



```
관리자: 명령 프롬프트 - nslookup
> set type=all
> wishfree.com
서버: [192.168.15.202]
Address: 192.168.15.202

DNS request timed out.
    timeout was 2 seconds.
wishfree.com  nameserver = windows-2016
wishfree.com
    primary name server = windows-2016
    responsible mail addr = hostmaster
    serial = 4
    refresh = 900 (15 mins)
    retry = 800 (10 mins)
    expire = 86400 (1 day)
    default TTL = 3600 (1 hour)
```

[실습 3-3] DNS 서버를 검색해 정보 수집하기

Is wishfree.com

① 실패

```
관리자: 명령 프롬프트 - nslookup
> ls wishfree.com
[[192.168.15.202]]
*** 도메인 wishfree.com을(를) 나열할 수 없습니다. Query refused
DNS 서버가 영역 wishfree.com을(를) 사용 중인 컴퓨터에 전송하는 것을 거부했습니다.
잘못된 경우에는 IP 주소 192.168.15.202의 DNS에서 wishfree.com의 영역 전송 보안 설정을
확인하십시오.
>
```

② 성공

```
선택 관리자: 명령 프롬프트 - nslookup
> ls wishfree.com
[[192.168.15.202]]
wishfree.com.      NS      server = windows-2016
db                 A       192.168.20.201
was                A       192.168.20.202
web                A       192.168.20.200
>
```

```
> ls yyy.com
[[192.168.0.18]]
*** 도메인 yyy.com을(를) 나열할 수 없습니다. Query refused
DNS 서버가 영역 yyy.com을(를) 사용 중인 컴퓨터에 전송하는 것을 거부했습니다.
잘못된 경우에는 IP 주소 192.168.0.18의 DNS에서 yyy.com의 영역 전송 보안 설정을
확인하십시오.

> ls zzz.com
[[192.168.0.18]]
zzz.com.           NS      server = zzz.com
zzz.com.           A       10.0.2.10
mail               A       10.0.2.10
www                A       10.0.2.15
>
```

DNS 레코드의 종류

표 3-3 DNS 레코드의 종류

종류	내용
A ^{Address}	호스트 이름 하나에 IP 주소가 여러 개 있을 수 있고 IP 주소 하나에 호스트 이름이 여러 개 있을 수도 있다. 이를 정의하는 레코드 유형이 A이며, 다음과 같이 정의한다. - www A 200.200.200.20 - ftp A 200.200.200.20
PTR ^{PoinTeR}	A 레코드와 상반된 개념이다. A 레코드는 도메인에 대해 IP 주소를 부여하지만 PTR 레코드는 IP 주소에 대해 도메인 이름을 매핑하는 역할을 한다.
NS ^{Name Server}	DNS 서버를 가리키며, 각 도메인에 적어도 한 개 이상 있어야 한다.
MX ^{Mail eXchanger}	도메인 이름으로 보낸 메일을 받는 호스트 목록으로 지정한다.
CNAME ^{Canonical NAME}	호스트의 다른 이름을 정의하는 데 사용한다.
SOA ^{Start Of Authority}	도메인에 대한 권한이 있는 서버를 표시한다.
HINFO ^{Hardware INFO}	해당 호스트의 하드웨어 사양을 표시한다.
ANY(ALL)	DNS 레코드를 모두 표시한다.

DNS의 특징을 이용한 공격

■ DNS cache Poisoning 공격

- DNS를 직접 공격
- recursive DNS의 캐시 정보를 변조
- recursive DNS를 사용하는 많은 클라이언트가 피해

recursive DNS를 속이는 공격을 하는 것

■ 스니핑 기반의 DNS spoofing

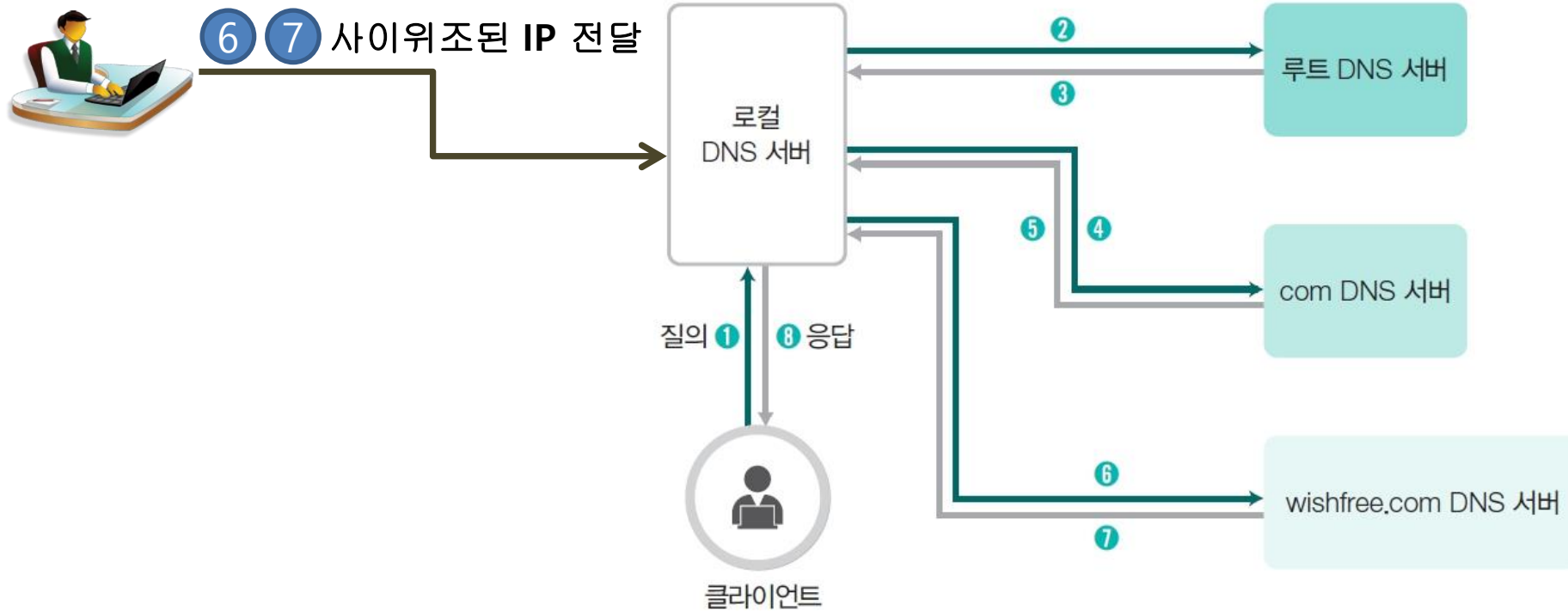
- DNS로부터 오는 메시지를 변조함
 - 특정 클라이언트가 피해!!

DNS 서버 보안 대책

■ DNS 스푸핑

■ DNS cache poisoning 공격

로컬 DNS 캐시에 위조된 IP 저장 후
8 위조된 IP 전달



DNS 서버 보안 대책

■ DNS 스푸핑

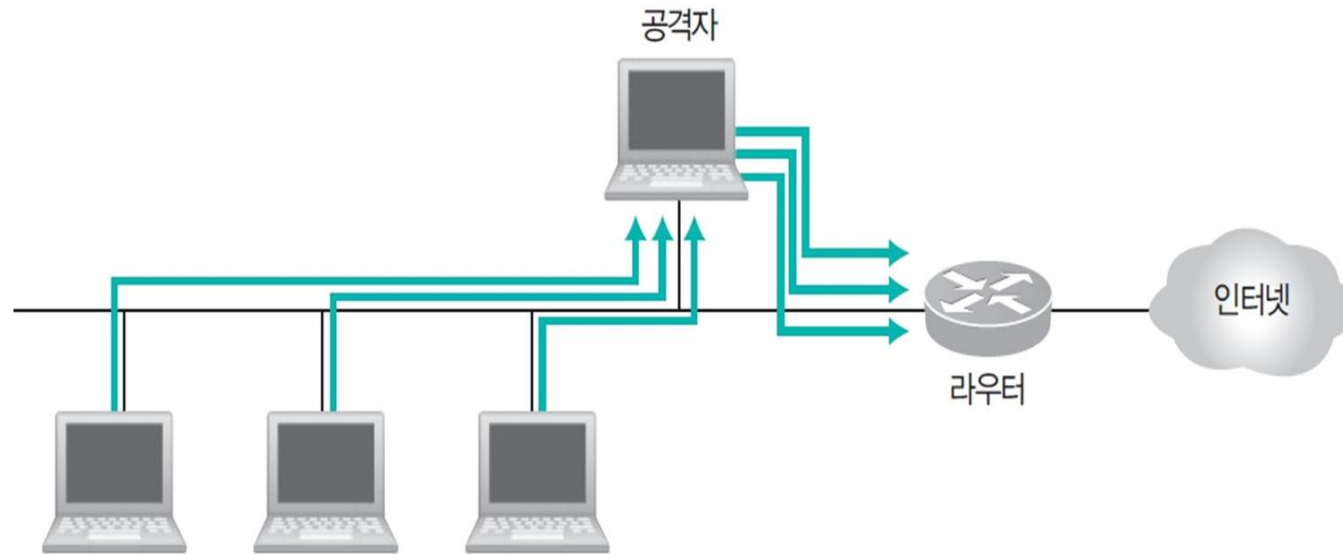
■ DNS cache poisoning 공격 대책

- recursive query 허용 안함
 - /etc/bind/named.conf.option
 - allow-recursion { none; }; 또는 특정 IP에 대해서만 허용하도록 설정 (10.0.2.16 또는 10.0.2.0/24)

DNS 서버 보안 대책

■ DNS 스푸핑

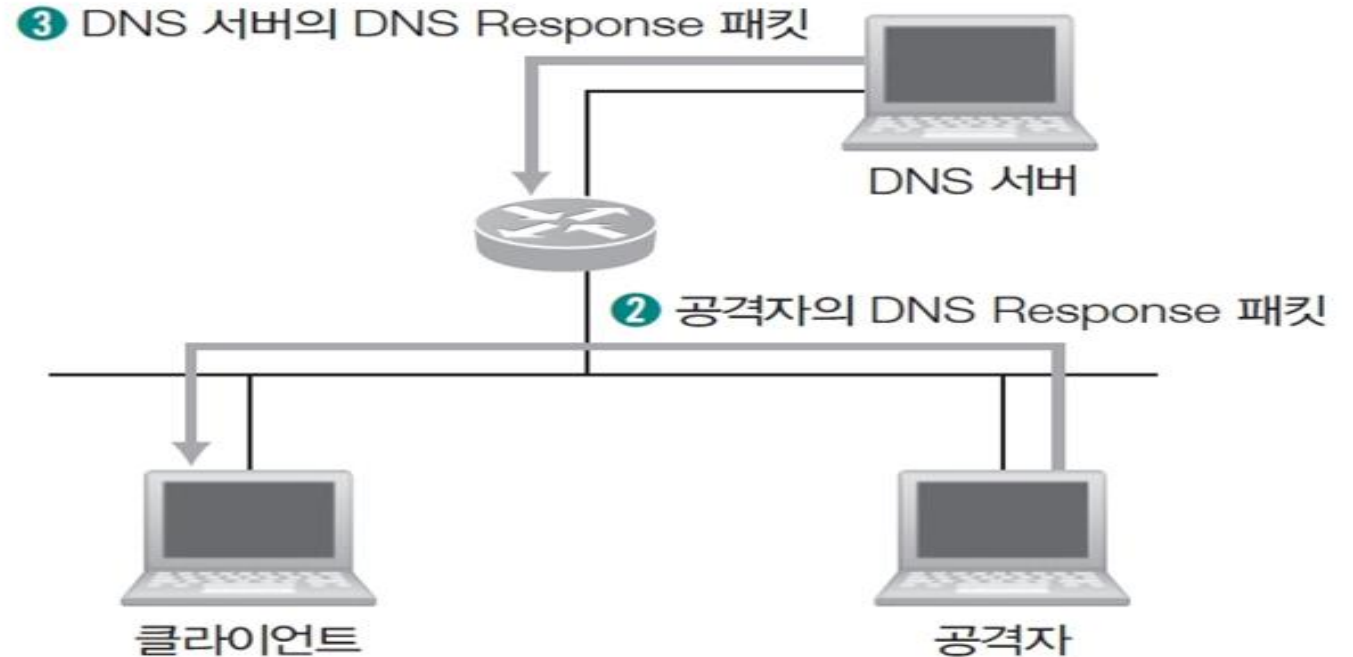
- 스니핑 기반 DNS 스푸핑 공격
 - 선제적으로 공격자에 의한 스니핑이 일어나고 있어야 함
 - arp 스푸핑(arp 리다이렉트)



DNS 서버 보안 대책

■ DNS 스푸핑

- 스니핑 기반 DNS 스푸핑 공격
 - 선제적으로 공격자에 의한 스니핑이 일어나고 있어야 함
- 보안 대책
 - 스니핑에 대한 대책



DNS 서버 보안 대책

■ DNS 스푸핑

- 보안 대책
 - 스니핑에 대한 대책

스니퍼 탐지(능동적인 보안 대책)

■ 스니핑 공격에 대한 대책

- 스니퍼가 프리미스큐어스 모드에서 작동한다는 점을 이용한 능동적인 탐지를 통해서만 잡아낼 수 있음
- 예) 강의실에서 대리 출석해주는 상황

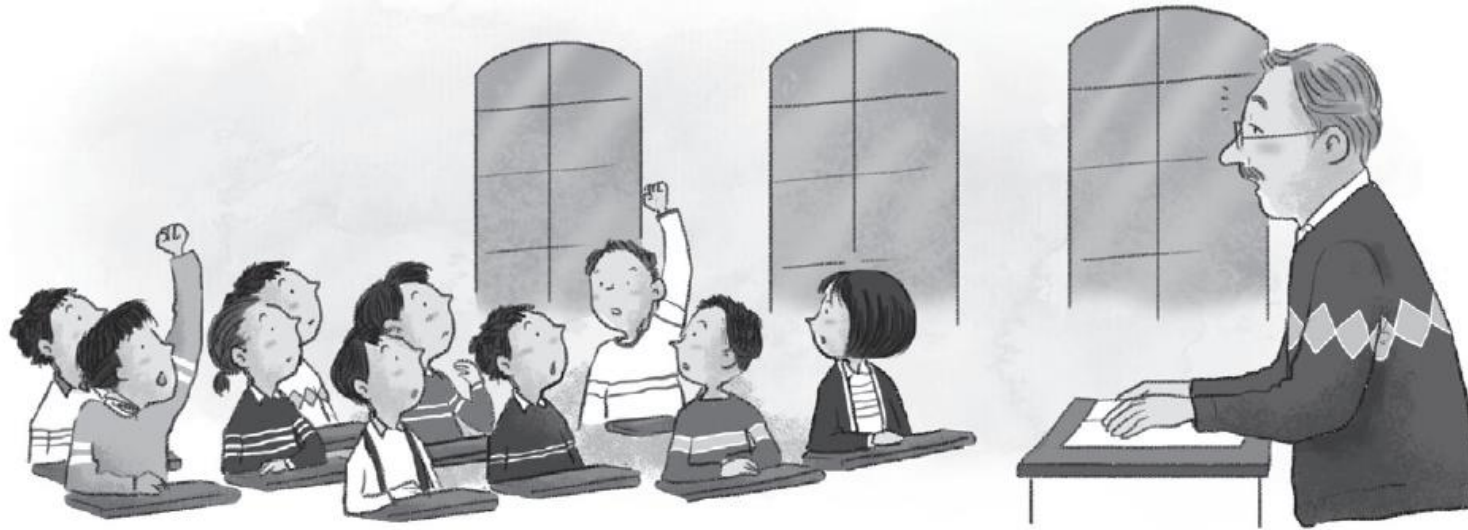


그림 6-8 스니퍼가 탐지되는 상황

스니퍼 탐지(능동적인 보안 대책)

■ ping을 이용한 스니퍼 탐지

- 네트워크에 존재하지 않는 MAC 주소를 위장해서 보내 자신에게 해당하지 않는 ping에도 ICMP Echo Reply를 되돌려 보내는 경우, 스니핑을 하고 있다고 탐지할 수 있음

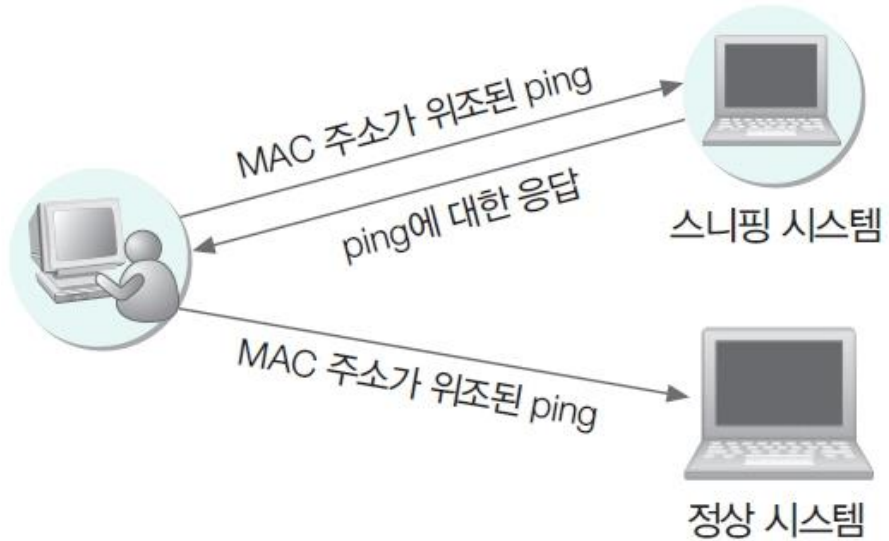


그림 6-9 ping을 이용한 스니퍼 탐지

스니퍼 탐지(능동적인 보안 대책)

■ ARP를 이용한 스니퍼 탐지

- ping 이용과 유사한 방법
- 위조된 ARP Request를 보냈을 때 ARP Response가 오면 프러미스큐어스 모드로 설정되어 있는 것

■ DNS를 이용한 스니퍼 탐지

- 테스트 대상 네트워크로 ping sweep을 보내고 들어오는 Reverse-DNS lookup을 감시해 스니퍼를 탐지

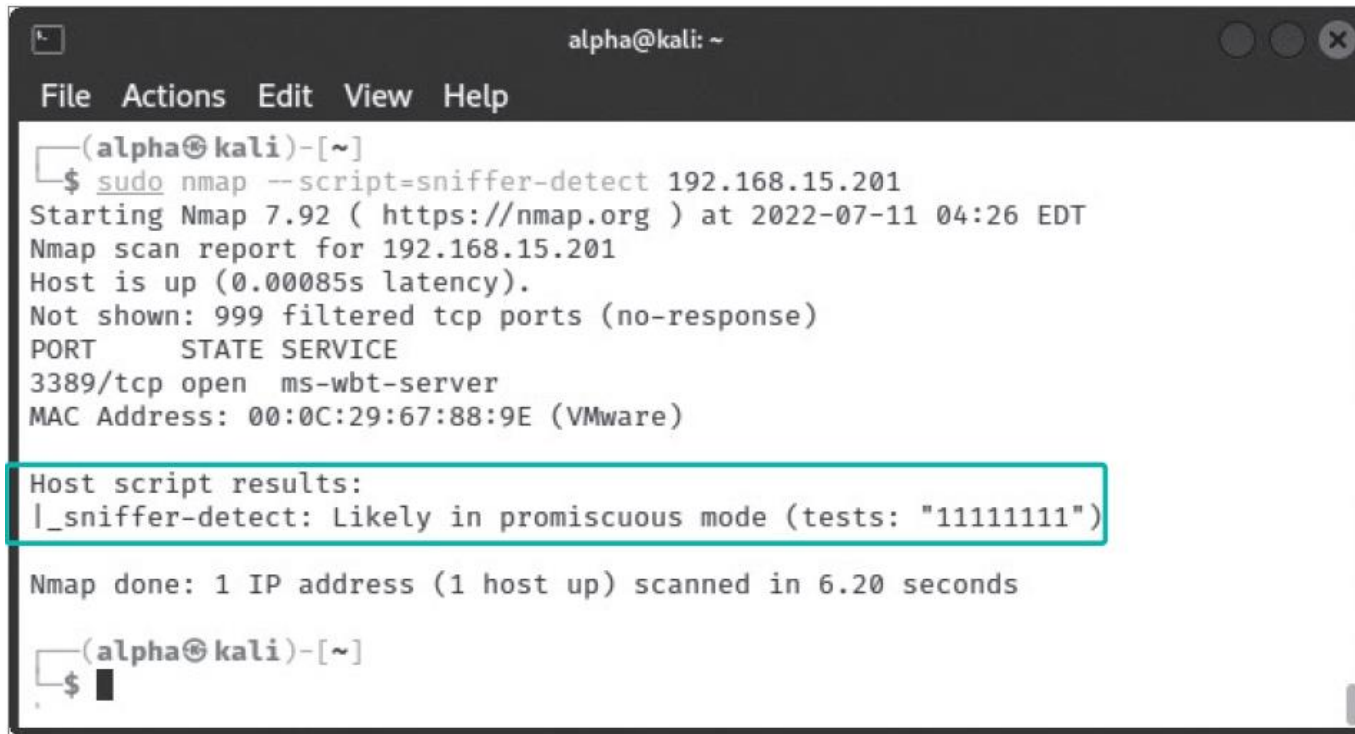
■ 유인을 이용한 스니퍼 탐지

- 보안 관리자는 가짜 아이디와 패스워드를 네트워크에 뿌린 후 공격자가 이 아이디와 패스워드로 접속을 시도하는 스니퍼를 탐지

스니퍼 탐지(능동적인 보안 대책)

■ ARP watch를 이용한 스니퍼 탐지

- ARP watch는 MAC 주소와 IP 주소의 매칭 값을 초기에 저장하고 ARP 트래픽을 모니터링해 이를 변하게 하는 패킷이 탐지되면 관리자에게 메일로 알려주는 툴
- nmap을 이용하면 특정 시스템이 스니퍼로 동작하고 있는지 확인 가능



```
alpha@kali: ~  
File Actions Edit View Help  
(alpha@kali)-[~]  
$ sudo nmap --script=sniffer-detect 192.168.15.201  
Starting Nmap 7.92 ( https://nmap.org ) at 2022-07-11 04:26 EDT  
Nmap scan report for 192.168.15.201  
Host is up (0.00085s latency).  
Not shown: 999 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
3389/tcp  open  ms-wbt-server  
MAC Address: 00:0C:29:67:88:9E (VMware)  
  
Host script results:  
|_sniffer-detect: Likely in promiscuous mode (tests: "11111111")  
  
Nmap done: 1 IP address (1 host up) scanned in 6.20 seconds  
(alpha@kali)-[~]  
$
```

그림 6-10 nmap을 이용한 스니퍼 탐지

암호화(수동적인 보안 대책)

■ SSL

- 암호화된 웹 서핑을 가능하게 함
- SSL은 많은 웹 서버 브라우저에 구현되어 있음
- 예) 쇼핑몰 사이트에 접속해서 물건을 구매하기 위해 신용카드 정보 등을 보낼 때 사용

■ PGP, PEM, S/MIME

- PGP와 PEM, S/MIME 모두 이메일을 전송할 때 사용하는 암호화 방법
- PGP는 내용을 암호화하는 데 IDEA 방법을 쓰고 IDEA 키와 전자 서명을 암호화하는 데 RSA 알고리즘을 씀
- PEM은 공개키 암호화 표준(PKCS)을 따르며 CA라는 공인된 인증기관에서 키를 관리
- S/MIME는 이메일 표준인 MIME 형식에 암호화 서비스만을 추가한 것이다

암호화(수동적인 보안 대책)

■ SSH

- 텔넷 같은 서비스 암호화를 위해 사용하는 것으로, 이미 설치한 OpenSSL 라이브러리가 SSH를 지원
- dsniff를 이용해 공격을 하면 SSH를 이용하더라도 공격을 당할 수 있음

■ VPN

- 원래 T1과 같은 사설 네트워크를 설치하는 데 많은 비용이 들기 때문에 한 회선을 여러 회사가 공유해 비용을 절감하려는 목적으로 개발된 것
- VPN을 제공하는 시스템이 해킹을 당할 경우 암호화되기 이전에 데이터가 스니핑이 될 수 있음

DNS 서버 보안 대책

■ 그 밖의 보안 대책

■ zone transfer 허용 안함

- /etc/bind/named.conf.option
 - allow-transfer { none;}; 또는 allow-transfer { 허용IP 나열 };
- 허용하면 관리 서버들의 주소를 모두 노출

■ DNS 서버의 버전 정보 숨김

- 버전에 대한 취약점이 노출될 수 있음.
- dig @DNS IP chaos version.bind txt <- dig 명령을 이용한 서버 버전 정보 질의
 - /etc/bind/named.conf.option 파일에서 version "unknown" 설정!!

Thank You !